

Project 6 – Footprinting, Reconnaissance, and Scanning

Name: **Bryan J Bonilla**

Date: **4/11/2026**

Part 1 – Passive Reconnaissance / OSINT

Task 1 – Whois: Domain Identity & Ownership

Instructions: Use a public Whois lookup for testphp.vulnweb.com (or its parent domain) and record the requested information below.

Domain: vulnweb.com

Registrar: **Gandi SAS**

Organization / Owner: **Invicti Security Limited**

Creation Date: 2010-06-14

Expiration Date: 2027-06-14

Name Servers: ns-105-a.gandi.net, ns-11-b.gandi.net and, cns-140-c.gandi.net.

Notes:

- **Ownership:** Registered by **Invicti Security Limited** in Malta via **Gandi SAS**, with a registration history dating back to June 2010.
- **Status & Expiry:** The domain is currently locked (**client transfer prohibited**) to prevent unauthorized moves and is valid through **June 14, 2027**.
- **Infrastructure:** It uses **Gandi name servers** for DNS, while the specific contact emails are **obfuscated** via a privacy proxy for security.

vulnweb.com

Updated 1 day ago

Domain Information

Domain:	vulnweb.com
Registered On:	2010-06-14
Expires On:	2027-06-14
Updated On:	2025-11-17
Status:	client transfer prohibited
Name Servers:	ns-105-a.gandi.net ns-11-b.gandi.net ns-140-c.gandi.net

Registrar Information

Registrar:	Gandi SAS
IANA ID:	81
Abuse Email:	abuse@support.gandi.net
Abuse Phone:	+33.170377661

Registrant Contact

Organization:	Invicti Security Limited
Country:	MT
Email:	e7c92ba29faca2e997bfc9ce58d5c661-57148476@contact.gandi.net

Task 2 – DNS Basics

Instructions: Use nslookup or dig for testphp.vulnweb.com and summarize the DNS information.

Command used: **nslookup testphp.vulnweb.com**.

IP address(es) observed: **44.228.249.3**

Record type(s) (A / CNAME / TXT, etc.): **A record**.

Additional notes: The domain resolves to an **Amazon AWS** infrastructure, the absence of multiple IP addresses suggests a single host and an A TXT record is also present for the parent domain.

```
labuser@LabVM:~$ dig testphp.vulnweb.com

; <<>> DiG 9.18.30-0ubuntu0.22.04.2-Ubuntu <<>> testphp.vulnweb.com
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 54985
;; flags: qr rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
;; EDNS: version: 0, flags:; udp: 65494
;; QUESTION SECTION:
;testphp.vulnweb.com.      IN      A
;; ANSWER SECTION:
testphp.vulnweb.com.      1713    IN      A      44.228.249.3

;; Query time: 0 msec
;; SERVER: 127.0.0.53#53(127.0.0.53) (UDP)
;; WHEN: Sat Apr 11 15:30:39 UTC 2026
;; MSG SIZE rcvd: 64
```

Task 3 – Hosting & Technology Stack

Instructions: Use Netcraft Site Report or a similar public site-technology report for testphp.vulnweb.com.

Tool used: **Netcraft Site Report**.

Hosting provider / ASN: **Amazon.com, Inc. / AS16509 (Amazon Data Services)**.

Country / Region: **United States / Oregon (us-west-2)**.

Web server / tech stack reported: The site runs on a **Linux** operating system, utilizing an **Nginx** or **Apache** web server to host a **PHP**-based backend.

Other observations: The site reveals detailed version info via the **X-Powered-By** and **Server** HTTP headers, which is a significant information disclosure vulnerability, and also It is hosted on an **AWS EC2** instance, as evidenced by the rDNS record.

Task 4 – Google Dorks on testphp.vulnweb.com

Instructions: Run at least three Google queries using operators (site:, inurl:, filetype:, "quoted phrase"). For each query, record one interesting result and why it might matter.

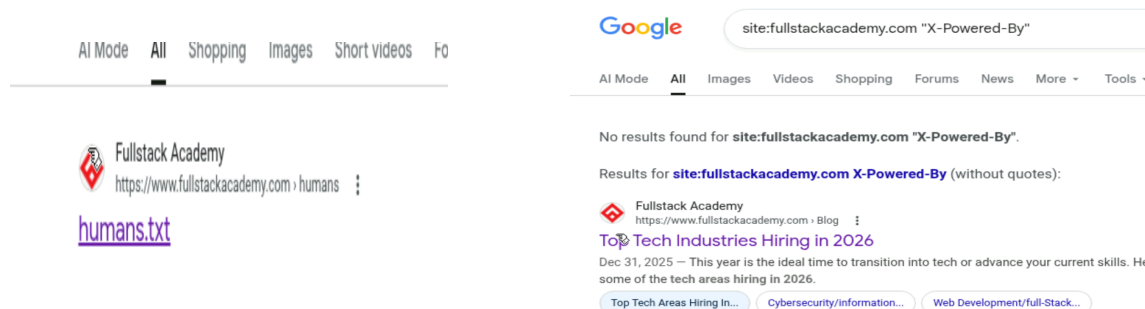
Query:	Interesting Result (Title/URL)	Why this might matter (attacker or defender)
site:testphp.vulnweb.com	The discovery of the /artists and /listproducts directories.	This confirms the site uses a database-driven structure where content is likely pulled via parameters. These are prime targets for SQL injection .
site:testphp.vulnweb.com filetype:php	artists.php, listproducts.php, and guestbook.php—uses the .php extension.	It confirms the specific backend technology (PHP). Since the results also mention "intentionally vulnerable," an attacker would look for known vulnerabilities in older PHP versions, such as file inclusion or code execution.
site:testphp.vulnweb.com inurl:login	The guestbook entry with the warning: <i>"This is not a real shop."</i>	A guestbook is a classic vector for Stored Cross-Site Scripting (XSS) . Because it accepts user input that is then saved and displayed to others, an attacker can try to "inject" malicious scripts here.

Task 5 – Light OSINT on fullstackacademy.com (Google Only)

Instructions: Run at least three Google searches using the site:fullstackacademy.com or its subdomains with at least one other operator. Record an example result and why it could matter from an OSINT or security perspective.

Query:	Interesting Result (Title/URL)	Why this might matter (attacker or defender)
site:fullstackacademy.com inurl:id	https://www.fullstackacademy.com/metrics/ns.html?id=GTM-TM5WF2W	These are classic targets for SQL Injection .
site:fullstackacademy.com filetype:txt	humans.txt	It can reveal the names or handles of the technical team, which provides a starting point for Social Engineering or searching for those individuals on LinkedIn and GitHub to find leaked code or personal interests.
site:fullstackacademy.com "X-Powered-By"	No exact matches found in Google's index.	This is a positive sign for the organization. It suggests that they are likely following security best practices by suppressing or stripping sensitive headers from their web pages and that these technical details haven't "leaked" into the indexed text of their site.

Screenshot filenames (if any):



Task 6 – Passive Recon Summary

Instructions: Summarize the overall exposure and key findings from your passive recon.

Summary for testphp.vulnweb.com (1–2 sentences):

Passive reconnaissance reveals a high level of exposure, as the site openly indexes functional PHP scripts and sensitive directories like `/admin` and `/guestbook`. The tech stack is clearly identifiable through leaked headers and Google Dorks, confirming an intentionally weak security posture.

Summary for fullstackacademy.com (1–2 sentences):

This site demonstrates a hardened security posture with minimal technical footprint exposure, successfully suppressing sensitive "X-Powered-By" headers and configuration files from search indexes. Passive findings are limited to non-critical files like `humans.txt`, indicating effective control over publicly available metadata.

Top 3–5 Passive Findings:

Finding (what you discovered)	Tool / Query used	Why it matters to a defender
<code>/artists</code> , <code>/listproducts</code>)	<code>site:testphp.vulnweb.com</code>	Exposes the site's internal structure and identifies specific scripts that may have input vulnerabilities like SQLi.
Exposed Backend Tech (Identified PHP version 5.3.10)	Netcraft Site Report / Header Analysis	Header AnalysisUsing outdated software versions allows attackers to look up specific, known exploits (CVEs) for that version.
Cloud Infrastructure Details (AWS EC2 hosting in us-west-2)	<code>nslookup</code> / Reverse DNS	Knowing the hosting provider helps an attacker understand the network environment and potential regional restrictions.

Recommended follow-up action for a defender (1–2 sentences):

The defender should immediately implement a strict `robots.txt` file to prevent search engines from indexing sensitive directories and disable directory listing on the web server. Furthermore, they must strip "X-Powered-By" headers and update the legacy PHP version to a supported, hardened release to minimize the identifiable attack surface.

Part 2 – Active Reconnaissance / Scanning (Metasploitable Lab)

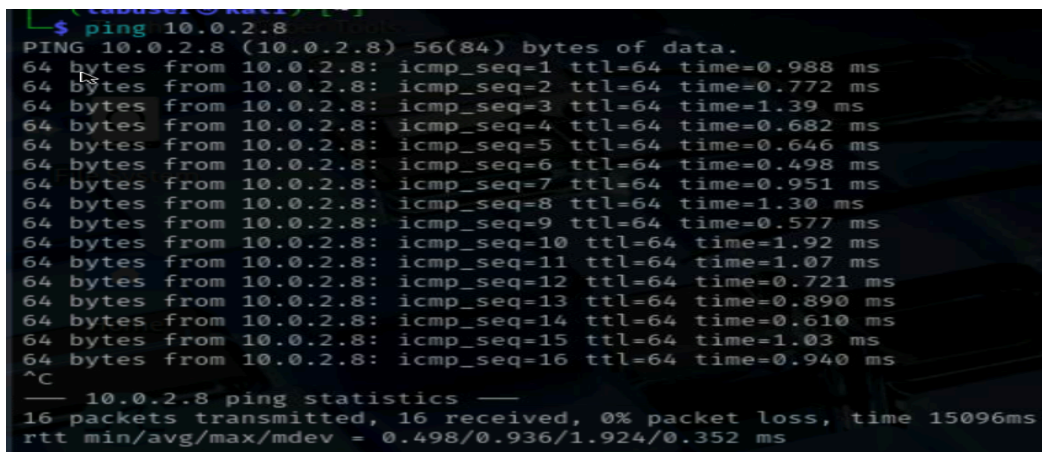
Task 7 – Confirm Connectivity (Kali → Metasploitable)

Instructions: Ensure your Kali system can reach the Metasploitable VM and record the details below.

Metasploitable IP address: **10.0.2.8**

Ping command used: **Ping 10.0.2.8**

Result summary (e.g., number of successful replies): **16 packets transmitted, 16 received, 0% packet loss.**



```
$ ping 10.0.2.8
PING 10.0.2.8 (10.0.2.8) 56(84) bytes of data:
64 bytes from 10.0.2.8: icmp_seq=1 ttl=64 time=0.988 ms
64 bytes from 10.0.2.8: icmp_seq=2 ttl=64 time=0.772 ms
64 bytes from 10.0.2.8: icmp_seq=3 ttl=64 time=1.39 ms
64 bytes from 10.0.2.8: icmp_seq=4 ttl=64 time=0.682 ms
64 bytes from 10.0.2.8: icmp_seq=5 ttl=64 time=0.646 ms
64 bytes from 10.0.2.8: icmp_seq=6 ttl=64 time=0.498 ms
64 bytes from 10.0.2.8: icmp_seq=7 ttl=64 time=0.951 ms
64 bytes from 10.0.2.8: icmp_seq=8 ttl=64 time=1.30 ms
64 bytes from 10.0.2.8: icmp_seq=9 ttl=64 time=0.577 ms
64 bytes from 10.0.2.8: icmp_seq=10 ttl=64 time=1.92 ms
64 bytes from 10.0.2.8: icmp_seq=11 ttl=64 time=1.07 ms
64 bytes from 10.0.2.8: icmp_seq=12 ttl=64 time=0.721 ms
64 bytes from 10.0.2.8: icmp_seq=13 ttl=64 time=0.890 ms
64 bytes from 10.0.2.8: icmp_seq=14 ttl=64 time=0.610 ms
64 bytes from 10.0.2.8: icmp_seq=15 ttl=64 time=1.03 ms
64 bytes from 10.0.2.8: icmp_seq=16 ttl=64 time=0.940 ms
^C
-- 10.0.2.8 ping statistics --
16 packets transmitted, 16 received, 0% packet loss, time 15096ms
rtt min/avg/max/mdev = 0.498/0.936/1.924/0.352 ms
```

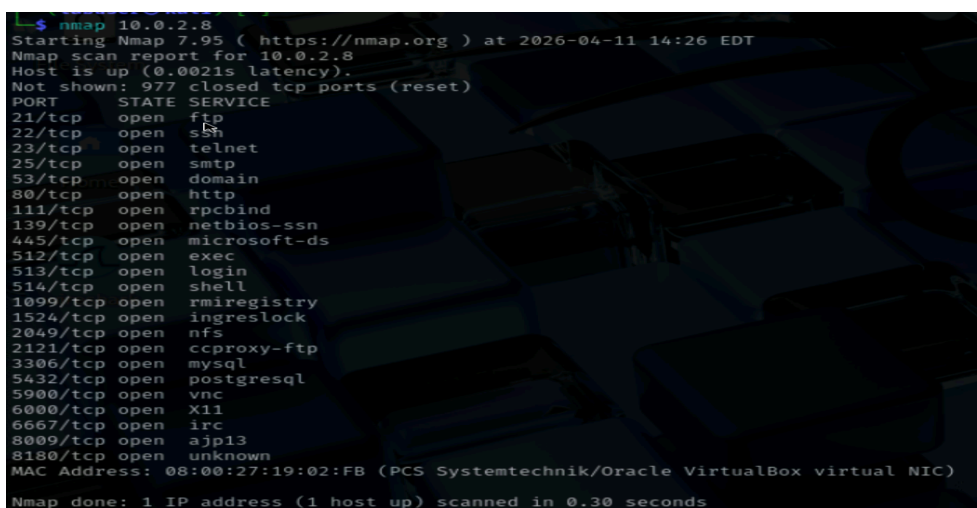
Task 8 – Basic Nmap Scan of Metasploitable

Instructions: Run a basic nmap scan against the Metasploitable IP address.

Nmap command used: **nmap 10.0.2.8**

General observations about the scan (number of open ports, anything that stands out): **23 open ports, services such as SSH, HTTP and FTP..**

Screenshot filename(s):



```
$ nmap 10.0.2.8
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-11 14:26 EDT
Nmap scan report for 10.0.2.8
Host is up (0.0021s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:19:02:FB (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 0.30 seconds
```

Task 9 – Port & Service Interpretation

Instructions: Choose at least five open ports from your nmap results. For each, describe the service, a potential risk, and a simple defense idea.

Port	Service	Potential Risk	Simple Defense Idea
21/tcp	FTP (File Transfer Protocol)	FTP often sends credentials and data in cleartext . An attacker could sniff the network to steal login info or perform "bounce" attacks.	Switch to SFTP or FTPS to encrypt the traffic and credentials.
23/tcp	Telnet	Like FTP, Telnet is unencrypted. It is a high-value target for man-in-the-middle (MITM) attacks and credential harvesting.	Disable Telnet immediately and use SSH for secure remote command-line access.
80/tcp	HTTP	Vulnerable to web attacks like SQL Injection or XSS . It also indicates the site isn't using SSL/TLS, exposing user data.	Implement an SSL/TLS certificate and use a Web Application Firewall to filter malicious traffic.
3306/tcp	MySQL	If exposed to the network, attackers can attempt brute-force login or exploit database vulnerabilities to dump sensitive user data.	Bind MySQL to localhost so it isn't reachable from the network, or use a strict firewall whitelist.
5900/tcp	VNC	VNC allows remote desktop access. Weak passwords or unpatched VNC software can lead to full graphical session hijacking .	Require MFA for access and tunnel VNC traffic through SSH rather than exposing the port directly.

Task 10 – Active Recon Summary

Instructions: In 5–7 sentences, summarize what your scan results say about the Metasploitable system's exposure and what a defender should prioritize.

Summary:

The Nmap scan of the Metasploitable system reveals an extremely critical level of exposure, characterized by dozens of high-risk services running in an unhardened state. The presence of legacy and unencrypted protocols such as Telnet, FTP, and Rlogin indicates that administrative credentials and sensitive data are likely being transmitted in cleartext across the network. Furthermore, the exposure of backend database ports like MySQL and PostgreSQL, alongside remote access tools like VNC and X11, provides multiple direct entry points for an attacker to gain full system control.

A defender must prioritize immediate surface area reduction by disabling all non-essential services and replacing unencrypted protocols with secure alternatives like SSH. Following this, the focus should shift to implementing a robust firewall policy that restricts access to the remaining necessary services to specific, authorized IP addresses. Finally, patching the underlying operating system and services is vital to mitigate the numerous known vulnerabilities inherent in this type of environment.

